

Cybernetic Security

Protection of Services and Data

February 2026

Tomáš Sochor
Dept. of Informatics
Faculty of Business and Economics, Mendel University

● MENDEL
● Faculty
● of Business
● and Economics

Lecture Agenda

Introduction
User roles/permissions in operating systems
Event audit
Data backup
Disk encryption

Intro: Operating Systems - Basic Terms and Principles

- Main risks for OS include:
 - Users with undesirable/malicious behavior
 - or their processes (applications),
 - Malicious software:
 - Both with possible impact on data.
- Countermeasures:
 - Authentication,
 - Access Control:
 - File Access Control (Users/Processes),
 - Memory Access Control (Processes),
 - Firewalls (OS-based),
 - IDS/IPS (OS-based),
- Prevention: backing up, ...

Operating System Hardening

- OS patching (regular),
- Proper OS configuration:
 - Removing unused services (potential vulnerability),
 - Resource controls,
 - Users, Groups, Permissions.
- User Security Policies:
 - Password policies, e.g.
 - min. password length & strength,
 - Character set enforcing (uppercase, lowercase, digits, special chars).
 - max. password entering attempts (before temp. account blocking).
- Auxiliary measures:
 - Logging, auditing.
 - Data backups & Archival.

1. User roles and permissions

Multuser OSs:

- almost every present OS
 - every server and desktop OS:
 - Windows,
 - Linux/unix,
 - MacOS,
 - ...
- Even seemingly single-user systems support multiple user accounts:
 - e.g. Android: <https://source.android.com/docs/devices/admin/multi-user>
- Any user can compromise an overall OS security.

1. User roles and permissions – Cont.

User account restrictions: 2 main types:

- File access,
- User account access (modification)
 - together with other object in access database
 - e.g. Active Directory (Windows).

User accounts types (usual):

- Administrator:
 - Usually no or few limitations,
 - e.g. root in unix: usernames could vary.
 - Multiple admin accounts can exist on a single machine.
- Ordinary user:
 - Any name (unique in the machine),
 - Permission set specified by administrator:
 - Individually or by groups.

User Accounts – Multiuser Operating Systems

■ Unix:

- 2 user account types
 - Ordinary user: obeying file attributes,
 - Root: unlimited file access.
- Switching users: `su`
- Authorization elevation: `sudo`
 - Only for users in `/etc/sudoers`
- More granular permissions could be applied in specific unix flavors (e.g. distributions).

■ Windows:

- More granularity in user permissions:
 - More preset user accounts (admin, power user, user, guest, ...).

User permissions in other OSs

Cisco IOS:

- In all routers and switches by Cisco.
 - Hierarchical modes:
 - User mode (almost no permissions, just display some configuration options, > prompt),
 - Privileged mode (display everything, optional password protection).
 - Customized privilege levels (sets of accessible actions) can be defined.
 - Optional user authentication:
 - Username+password (local or RADIUS authentication).
 - For remote access (ssh/telnet):
 - Can be limited to specific IP addresses only (via ACLs).
 - For console access (direct serial rollover cable).

Other vendors: similar possibilities:

- E.g. Mikrotik: username+password, IP address filtering, changing the service port number, disabling some features, ...

User accounts security

- Relying solely on password security can be risky
 - No sole password is secure enough
- Additional level of security is required:
 - Restricting remote logging in:
 - e.g. defining a list of permitted locations (IP addresses):
 - Not flexible enough (in some cases).
 - Limiting number of failed login attempts:
 - Making both dictionary and brute-force attack complicated.
 - Replacing logging via password with a public key:
 - User generates a key pair on their PC, uploads a public key to the server and then they receive a “random” string when trying to log in and after encrypting with private key, it is sent back to the server.
 - Using Multifactor authentication with e.g. a mobile authenticator app.
 - ...

File Access Control – Basics

- Access to files is given to users/processes via a set of permissions:
 1. Read,
 2. Write (usually overwrite),
 3. Execute,
 4. Navigate,
 5. Modify contents,
 6. User permission modification,
- 2 prevailing approaches:
 - POSIX (1-3 above),
 - Access Control Lists:
 - inside the file system (e.g. NTFS, or in inodes in Unix ext file systems), or
 - separate.

File Access Control – Implementation

- Unix:
 - Common access attributes
 - `-rwxr-xr-- 200 file1`
 - SELinux
 - ACL
 - `Getfacl, setfacl` commands
 - Allows to add a combination of `rwx` attribs to any other user/group
- Windows:
 - ACL:
 - Associated to a file/directory
 - ACL is a complex combinations of multiple ACEs:
 - ACE:
 - user/group/computer (identified by SID)
 - {Allow|Deny} Read/Write/List Contents
 - Sometimes confusing (for complex Allow/Deny rules combination).

2. Event Auditing

Auditing: process of verification a compliance:

- To a law, rule, etc.

Audit logs:

- Similar to ordinary logs
 - Enriched with some more data (in most cases),
 - Better secured:
 - Privileged permission process (so that it cannot be stopped by users),
 - Audit log files (database) must not be accessible for users:
 - The audit logging software is “closed system”:
 - Not the only approach but prevailing.

Event Auditing – Audit Logs

Audit logs (audit trail) must include:

- Event name and description (easy to understand):
 - **What** happened?
- Event timestamp (in synchronized time):
 - **When** did it happen?
- Actor (user or process ID):
 - **Who** did the event?
- Impacted objects:
 - Device ID,
 - IP address, etc.
- Other info (depending on the event type):
 - e.g. processes running on the device at the time of the event.

Event Auditing – Log Types

Audit logs vs. Regular logs:

- Different purpose:
 - **Audit logs** serve for keeping a permanent (immutable) track of important events in the (software and hardware) system.
 - Usually kept for long time (years).
 - Kept for compliance (law), or business purposes.
 - Immutability of logs (restricted and controlled access).
 - Ordinary logs serve (to administrators, developers) for learning what happened in the system recently:
 - May not be centralized (different storage locations, e.g. servers).
 - Usually short-term (max. months).

3. Data Backup

- Various tools differing among platform (OS).
- Backup targets:
 - External devices (Local/Shared),
 - Shared/Server HDD/SDD,
 - Cloud (Private/Public).
- Objectives for Recovery:
 - RPO (Recovery Point Objective):
 - What part of existing data MUST be always recovered (after a failure)
 - e.g. last evening
 - influences HOW OFTEN the backup should take place
 - and related parameter,
 - RTO (Recovery Time Objective):
 - How quickly the recovered system MUST be ready for use:
 - i.e. Standby server HW is available? With OS installed? ...

3. Data Backup – Verification

- Every backup MUST be verified:
 1. Integrity of files;
 2. Ability to be recovered.
 - So that the user learn the procedure of recovery.
 - And to verify the completeness (all files are included).
- The second aspect (recoverability) is tested:
 - Periodically (e.g. twice a year), and
 - Anytime when a change in backup procedure happens,

3. Data Backup – Possible Issues

- Backup Issues:

- Proper setting of RPO/RTO:
 - Timely restoring data:
 - **Business continuity.**
 - Economic efficiency,
 - Avoiding too high costs for backup (storage etc.).
- Backup protection:
 - Integrity: avoiding later modification:
 - Targeted attack,
 - Ransomware,
 - User negligence.
 - Avoid **permanently connected** storage!
 - Easy infection of data in case of an attack.
 - Follow 3-2-1-0 rule for backups.

4. Disk Encryption

- Data backups are vulnerable:
 - Primarily on external devices:
 - Lack of protection,
 - Not only backups: all data on external/removable devices can be stolen easily.
 - Also a whole mobile device can be lost.
- Whole disk encryption is recommended for:
 - External storage devices (removable),
 - Mobile device storage,
 - Any other device containing data that can be physically lost.

4. Disk Encryption

- Encryption of data can improve the protection.
 - Disk encryption - prevailing approach:
 - Creation of a new partition on a disk
 - Consuming most of the available space.
 - All data on the new partition are encrypted:
 - Usually, symmetric (fast) encryption is used (with strong = long password).
 - The encrypted partition can be accessed only through a specialized client asking for the password for the first access from the computer.
 - All data are decrypted when accessed for reading/encrypted before writing (on-the-fly).

4. Disk Encryption – Cont.

- Available in various desktop (personal) OS:
 - Windows: BitLocker,
 - MacOS: FileVault,
 - Third-party software is also available
 - With OS integration.
 - Also, encryption could be an OS-independent feature of an external disk:
 - Supported by the access software provided by the disk producer.
 - Could be supplemented with a biometric factor (e.g. a fingerprint).
- Not so widely used in servers:
 - Low risk of server hardware or disk physical loss.

Questions? Comments?

Tomáš Sochor
Department of Informatics
tomas.sochor@mendelu.cz

● MENDELU
● Faculty
● of Business
● and Economics



Thank you for your attention

Tomáš Sochor
FBE MendelU
tomas.sochor@mendelu.cz

● MENDELU
● Faculty
● of Business
● and Economics